Task description: Custom CA Verifier for Firefox

Student:

Name: Avadhoot Pravin Khedekar

Mat.Nr: 5249247

Study program: DSE

Problem description:

Web browsers use Transport Layer Security (TLS) to protect connection to the website's servers.
The X.509 certificates that are necessary for this are verified as follows: Each browser has a database/store of trusted Certificate Authorities (CAs) and the certificate coming from a server must be ultimately signed by one of those CAs.

Users can install their custom trustworthy CAs, but cannot enforce that a certain CA must be used for certificates coming from some specific domains.
This leaves room for a powerful attacker to (wrongly) obtain a certificate from another CA and to be allowed by the browsers verification.
It becomes especially problematic, if the trustworthy CAs perform some special kind of server verification others don't.

The objecive is therefore to "pin" a domain to one ore more specific CAs.
This project focuses on the Firefox browser and its Gecko web engine.

Proposed solution

We imagine a patched Firefox Browser with modified Certificate handling.
It would add support for policies in its configuration that allow to specify domains and the mandatory CAs.
Upon establishment of the connection to a website, the patched Firefox Browser would evaluate whether the site falls under a policy.
If so, it would verify that the chain of the website's certificate links to one of the CAs listed in the policy.
If not, the already existing certificate verification mechanism would be used.

This approach looks simple at first glance, yet the details might be challenging:

1. There are a lot of details in certificate verification, such as:
    - Tranparancy Logs
    - Certificate Revocation Lists (CRLs)
    - Certificate Stapling

- We expect from the student to examine the whole process closely and decide which of the details are relevant for our approach

2. Domain names might contain wildcards, so the decision between "normal verification" and "special handling" ist not that trivial
3. Browser configuration can often be decided at the level of system administrators. Companies usually use browser configuration to restrict how their employees might browse the web.
   This is especially important to prevent employees from bypassing the browser's security mechanisms.
   For our project, we assume that Certificate Verification Policies will often be decided on company level and must not be altered by employees.
   We therefore need a way to use the existing browser's configuration toolset that alredy can prevent unpriviledged users from altering browser configuration to make our policies protected.

Tasks

The student must:

- Carry out a short literature review, identifing alternative, existing and failed approaches to this problem
- Dress a map of the existing certificate verification in Firefox and integrate the special handling into it
- develop ore use an algorithm to distinguish the domains where a certain CA is required from those whrere the usual approch is the right one
- Implement the verification against a specific (list of) CA, including special cases, such as CRLs and Certificate Stapling
- Use existing configuration protection mechanisms to allow an organization to fix the policies and prevent unpriviledged users from altering them
- Integrate the solution into a Nightly Firefox Browser
- Provide automated builds and an easy integration of an upstream update
- Evaluate the Solution against a non-modified Firefox. The overhead for the custom verification is expected to be neglegible
- Evaluate the Browser against the Top 100 visited sites, certificates known to be compromised, and a set of custom domains to be decided by the supervisor
- Document the setup and the resulting policy

The student might:

- compare his approach to previous standardisation attempts
- compare his solution to a classical browser extension

Note regarding the usage of AI tools

The student is encouraged to use AI tools for the implementation of his browser modification. He also might use AI to help with evaluating his solution.
AI usage has to be mentioned in the report, eventual `AGENTS.md` files or similar are expected to be put into the annex of his report.
The student is expected to write the report by himself, he is allowed to use spellcheckers and grammar tools, but paragraphs written out of prompts are forbidden.
The student is also expected to read and refer the sources he uses by himself, hallucinated references or wrong summaries of scientific articles will lead to point deduction.